

Lezione 5 – Le difficoltà nel combattere lo spam

Reti di calcolatori

Modulo 3 - Protocolli applicativi

Unità didattica 3 – Protocolli di posta elettronica

Ernesto Damiani

Università degli Studi di Milano - Ssri - CDL ONLINE

Tecniche anti-spam

- Per neutralizzare le tecniche di spam basate sulla tecnica 'No Relay' si potrebbe, in teoria, **adottare il blocco degli indirizzi IP dinamici**
 - Si tratta, però, di un approccio **poco pratico**, perché non esiste un semplice test per stabilire se un indirizzo IP è assegnato dinamicamente o meno
- Un'altra tecnica interessante è quella delle cosiddette **honeypot**, costituite da finti **server SMTP poco scrupolosi e da caselle di posta non corrispondenti a utenti reali**, cioè vere e proprie **trappole** che catturano gli indirizzi IP dei server SMTP usati dagli spammer
 - In pratica, però, la **latenza necessaria per diffondere le segnalazioni delle honeypot** le rende molto più **indicate per attivare contromisure legali che per reazioni in tempo reale all'invio di spam**

Filtraggio orientato al contenuto

- In generale, il filtraggio basato sull'IP del server SMTP mittente si è gradualmente rivelato un metodo antispam poco pratico e all'inizio degli anni Duemila la lotta allo spam ha preso un'altra direzione: **il**

filtraggio orientato al contenuto

- La maggior parte degli spammer invia a **tutti i destinatari una copia dello stesso messaggio**
 - Quando abbastanza **utenti di posta segnalano un messaggio sospetto**, mettendolo nella cartella "Junk Mail" dei loro client, il messaggio incriminato (o meglio un suo hash MD5) viene **aggiunto a una lista che viene poi condivisa tra i server SMTP attraverso servizi di notifica simili a quelli usati per gli antivirus**
 - I server SMTP scartano i messaggi di posta in arrivo il cui hash MD5 corrisponde a uno di quelli nella lista dello spam

SpamAssassin (1)

- **SpamAssassin** è un software che identifica automaticamente lo spam e oggi è la soluzione di riferimento
 - Per identificare lo spam esegue una serie di **verifiche sull'intestazione e un'analisi del testo del messaggio**
 - Inoltre, **usa alcune blacklist di MTA sospetti reperibili in Rete**.
 - Dopo essere stato identificato, lo spam viene contrassegnato con un punteggio che si aggiunge all'intestazione del messaggio, in modo che quest'ultimo possa poi essere filtrato dal client di posta dell'utente

SpamAssassin (2)

- Ecco un esempio dell'aggiunta generata da SpamAssassin:

```
- spamassassin: 3.2.1. perlscan: 1.25st.  
Clear:RC:0(159.149.10.22):SA:0(3.8/6.0):.  
Processed in 2.340732 secs); 09 Dec 2008 00:00:03  
-0000 X-Spam-Status: No, hits=3.8 required=6.0
```

- Per gli esempi di spam, SpamAssassin si basa su **Vipul's Razor**, una rete distribuita e collaborativa di identificazione dello spam grazie alla quale è stato costruito un catalogo costantemente aggiornato dei messaggi di spam in circolazione

Teorema di Bayes (1)

- La **soluzione bayesiana** proposta da Paul Graham si basa sullo **studio statistico del contenuto** dei messaggi
- Un filtro bayesiano decide se un messaggio è spam o no **in base alle parole contenute nei messaggi** ricevuti da uno specifico utente
 - Per ricordare il teorema di Bayes usiamo un esempio
 - Abbiamo un'osservazione O ("un messaggio contiene la parola "sex") e un'ipotesi H ("un messaggio è spam"). $P(O|H)$,
 - La probabilità che O accada dato H, ovvero la **probabilità che un messaggio spam contenga la parola "sex"**, può essere stimata esaminando la cartella "Junk Mail" in cui il destinatario mette lo spam e contando quanti dei messaggi che vi si trovano contengono "sex"

Teorema di Bayes (2)

- Per il filtro, ci interessa $P(H|O)$, la probabilità che H accada dato O, e cioè che un messaggio indirizzato a quell'utente e che contiene la parola "sex" sia effettivamente spam
- Secondo il teorema di Bayes tale probabilità è:

$$P(H|O) = P(O|H) * P(H) / P(O)$$

- $P(H)$ (la probabilità che un messaggio sia spam) e $P(O)$ (la probabilità che un messaggio contenga la parola "sex") possono essere stimate esaminando le caselle dell'utente
 - $P(H)$ si stima esaminando la cartella "Junk Mail" dove l'utente mette lo spam e contando quanti sono i messaggi di spam rispetto al totale dei messaggi
 - $P(O)$ si stima contando quanti messaggi contengono "sex" sul totale dei messaggi (spam o no) ricevuti dall'utente
- Le esperienze di Graham ci dicono che il filtro perde solo 5 messaggi di spam ogni 1000

Spammer all'attacco (1)

- Anche se in un primo tempo il **filtraggio collaborativo** fu efficace, gli spammer possono aggirarlo usando tecniche di **personalizzazione delle liste dei destinatari (list splitting)**, aggiungendo ai messaggi di spam delle **porzioni dipendenti dal destinatario**
- La comunità della ricerca informatica si è dedicata alle tecniche automatiche di riconoscimento dello spam; ma gli spammer hanno reagito a queste tecniche di riconoscimento **spostando la parte informativa dei loro messaggi all'interno di immagini**

Spammer all'attacco (2)

- Il fatto che la localizzazione di caratteri all'interno di un'immagine sia un problema facile per un utente umano ma difficile per un software oggi è sfruttato da molti siti Web per evitare la compilazione automatica delle form

- Gli spammer usano la stessa tecnica: generano immagini contenenti il loro testo
 - Questa tecnica è alla base dell'epidemia di **spam grafico**, in cui il testo dello spam è convertito in immagini
 - Se le immagini usate dagli spammer fossero davvero personalizzate per ciascun destinatario, la tecnica grafica sarebbe impossibile da controbattere
 - Per fortuna molti spammer non hanno i mezzi per generare le immagini e per applicare fino in fondo il list splitting

Contromisure (1)

- Una prospettiva nuova è togliere agli spammer la loro “benzina”, cioè gli indirizzi di posta
 - Gli spammer usano programmi appositi (detti **harvester** o **spambot**) che scaricano le pagine Web alla ricerca di indirizzi di posta a cui mandare spam
 - Alcuni siti usano delle semplici precauzioni per evitarlo, pubblicando indirizzi “antispam” come ernesto.damiani AT unimi DOT it
 - Questo metodo, però, è facilmente aggirato dagli spambot più recenti
 - Altri cercano di difendersi dagli harvester con le loro stesse armi, pubblicando immagini che mostrano gli indirizzi di mail invece degli indirizzi in formato testo (ma questa precauzione può non essere gradita ai visitatori umani)

Contromisure (2)

- Altri siti usano la **codifica carattere per carattere HTML**, ad esempio usando `@` per il carattere chiocciola (@) o per tutti i caratteri dell'indirizzo
 - Ecco la codifica dell'indirizzo `someone@example.com`:
`someone@ex`
`ample.com`
 - Anche questo tipo di codifica è facile preda degli harvester, perché ogni carattere corrisponde esattamente a un codice secondo una tabella ben nota
 - Le **tecniche crittografiche**, invece, si basano su una codifica crittata dell'indirizzo di mail che viene decrittata da uno script solo al momento dell'utilizzo dell'indirizzo di posta elettronica, quest'ultimo, quindi, non compare da nessuna parte nella pagina

